

EVALUASI CELAH KEAMANAN WEBSITE PONDOK PESANTREN MENGGUNAKAN METODE AUTOMATED SCANNING DAN METRIK CVSS V3

Lukman Nur Rahman¹

¹. Teknik Informatika STMIK Tazkia

¹241552010007.lukman@student.stmik.tazkia.ac.id

Dosen Pengampu: Hendri Karisma, M.T.



SEKOLAH TINGGI MANEJEMAN INFORMATIKA

KOMPUTER (STMIK) TAZKIA

TEKNIK INFORMATIKA

2024/2025

BAB 1 PENDAHULUAN

1.1 Latar Belakang

Teknologi aplikasi berbasis web semakin berkembang saat ini telah mengubah manajemen data secara luar biasa, namun berbanding lurus dengan itu peningkatan risiko serangan siber semakin agresif. Di dalam ruang lingkup ilmu komputer, penyebaran celah keamanan (web vulnerabilities) pada kode penyusun aplikasi menjadi titik masuk utama bagi aktor ancaman untuk mengeksploitasi sistem secara ilegal/tak sah. Menghadapi jumlah aplikasi web yang masif, pengujian keamanan secara manual tidak lagi efisien, sehingga komunitas keamanan komputer global beralih menggunakan arsitektur pemindaian otomatis (automated vulnerability scanning) guna mendeteksi kecacatan/bug sistem secara real-time. Kelebihan alat pemindaian ini diukur secara objektif melalui metrik komputasi yang ketat guna memastikan tingkat presisi deteksi serta meminimalkan kemunculan alarm palsu (false positives) yang dapat mengaburkan tingkat risiko sistem yang sebenarnya [1], [2].

Risiko ini semakin menjadi kritis ketika bergeser ke sub-domain website lembaga pelayanan publik dan institusi pendidikan formal. Portal resmi milik institusi akademik kini menjadi target utama serangan siber karena menyimpan pangkalan data (database) informasi pribadi berskala besar. Di sisi lain, infrastruktur perlindungan teknisnya karena berbagai faktor sering kali terabaikan. Kerentanan pada portal akademik dan web pemerintahan umumnya disebabkan oleh lemahnya tata kelola pembaruan sistem (patching management) serta konfigurasi server yang tidak sesuai standar. Kegagalan dalam mengidentifikasi titik lemah pada perimeter luar web pendidikan juga berpotensi mengakibatkan serangan fatal seperti infiltrasi basis data, defacement halaman muka, hingga pemodelan serangan tingkat lanjut yang dapat melumpuhkan sistem informasi akademik secara total [3], [4], [5], [6].

Penelitian terdahulu telah ada yang mengevaluasi efektivitas pemindaian otomatis ini pada berbagai platform aplikasi web akademis dan finansial. Berbagai pengujian empiris membuktikan bahwa penggunaan alat bantu seperti OWASP ZAP Engine memiliki performa yang sangat optimal dalam memetakan distribusi tingkat bahaya kerentanan berdasarkan parameter formal. Evaluasi komparatif versi perangkat lunak juga menunjukkan bahwa pembaruan mesin pemindai secara signifikan meningkatkan akurasi automated

spidering dalam mendeteksi celah kritis. Melalui visualisasi data kuantitatif yang mengelompokkan peringatan bahaya (alerts) ke dalam kluster peringkat risiko, para peneliti terdahulu berhasil merumuskan status keamanan siber secara matematis pada domain website universitas berskala besar maupun portal layanan keuangan syariah [7], [8], [9].

Namun demikian, terdapat research gap yang sangat nyata dalam literatur keamanan siber saat ini. Mayoritas kajian terdahulu di Indonesia masih sangat terbatas pada tinjauan pustaka sekunder yang bersifat umum, serta studi empiris yang terlalu berfokus pada dimensi sosial-perilaku manusia, seperti tingkat kesadaran siber (cybersecurity awareness) dan edukasi literasi digital para santri di lingkungan pondok pesantren. Di samping itu, publikasi review yang ada hanya merangkum data statistik tanpa menyentuh aspek teknis langsung objek di lapangan. Akibatnya, hingga saat ini belum ada penelitian komputasi murni yang menguji dan mengukur secara kuantitatif tingkat kerentanan sistem pada website resmi Pondok Pesantren di Indonesia menggunakan metode pemindaian otomatis yang distandarkan dengan standar metrik keparahan kalkulator CVSS v3. Padahal nyatanya, web pesantren memiliki karakteristik tata kelola infrastruktur yang rentan terhadap eksploitasi siber [10], [11], [12], [13], [14], [15].

Untuk menjembatani research gap teknis tersebut, penelitian ini mengusulkan sebuah pendekatan evaluasi keamanan siber kuantitatif dari sisi performa sistem komputer. Solusi yang diajukan adalah melakukan pemindaian kerentanan mendalam secara otomatis (automated web vulnerability assessment) pada berbagai portal web resmi pondok pesantren aktif di Indonesia menggunakan perangkat lunak OWASP ZAP. Data mentah berupa temuan jenis kelemahan (weakness flags) dari hasil pemindaian kemudian diekstrak dan dikonversi ke dalam skala nilai numerik (0.0 hingga 10.0) menggunakan kalkulator standar Common Vulnerability Scoring System version 3 (CVSS v3). Pendekatan ini memberikan kesempatan penilaian tingkat keparahan risiko siber dilakukan secara presisi, objektif, dan berbasis data angka riil komputer, bukan opini subjek manusia.

Urgensi dari pelaksanaan riset ini terletak pada pemberian evaluasi teknis pertahanan siber bagi institusi pendidikan Islam tradisional yang tengah menghadapi gelombang transformasi digital massal. Hasil kalkulasi metrik angka ini nantinya dapat dijadikan landasan utama bagi pengelola teknologi pesantren untuk melakukan tindakan mitigasi dan penambalan celah keamanan sebelum dieksploitasi oleh pihak luar. Berdasarkan latar

belakang piramida terbalik tersebut, penelitian ini dilakukan dengan judul: “Evaluasi Celah Keamanan Website Pondok Pesantren Menggunakan Metode Automated Scanning dan Metrik CVSS v3”.

1.2 Rumusan Masalah

Berdasarkan pembatasan masalah pada latar belakang di atas, maka rumusan masalah kuantitatif dalam penelitian ini adalah sebagai berikut:

1. Berapa jumlah total dan distribusi persentase celah keamanan berdasarkan kategori tingkat risiko (High, Medium, Low, Informational) yang terdeteksi pada website pondok pesantren menggunakan metode automated scanning OWASP ZAP?
2. Berapa rata-rata nilai skor keparahan (severity score) kerentanan sistem pada website pondok pesantren jika dihitung menggunakan kalkulator metrik Common Vulnerability Scoring System version 3 (CVSS v3)?
3. Berapa persen dari total sampel website pondok pesantren yang diuji memiliki celah keamanan kritis berkategori High Risk (skor CVSS v3 ≥ 7.0) yang rentan terhadap risiko eksploitasi data secara langsung?

1.3 Tujuan Penelitian

Sesuai dengan rumusan masalah yang telah ditetapkan, tujuan yang ingin dicapai melalui penelitian ini adalah:

1. Mengidentifikasi dan menghitung jumlah serta distribusi persentase celah keamanan berdasarkan kategori tingkat risiko (High, Medium, Low, Informational) di website pondok pesantren menggunakan kakas bantu pemindaian otomatis OWASP ZAP.
2. Mengukur dan menganalisis secara kuantitatif rata-rata nilai skor keparahan (severity score) kerentanan pada website pondok pesantren berdasarkan standar metrik kalkulator CVSS v3.
3. Mengalkulasi persentase website pondok pesantren yang masuk dalam kondisi bahaya kritis (High Risk) guna memetakan tingkat bahaya dan prioritas mitigasi pertahanan siber di lingkungan pesantren.

1.4 Manfaat Penelitian

Pelaksanaan riset ini diniatkan sebagai bentuk ikhtiar dari sisi ilmiah yang diharapkan dapat memberikan kontribusi nyata, baik secara keilmuan maupun praktis demi kemaslahatan umat era digital.

1.4.1 Manfaat Bagi Ilmu Pengetahuan (Teoretis)

- Bertambahnya Khazanah Keamanan Siber Lembaga Islam. Penelitian ini berkontribusi dalam memperluas taksonomi ilmu keamanan komputer, khususnya dalam memetakan karakteristik serta postur kerentanan sistem informasi pada institusi pendidikan Islam tradisional yang memiliki tata kelola infrastruktur mandiri.
- Integrasi Metrik Kuantitatif Formal pada Objek berbasis komunitas keagamaan. Menjadi referensi ilmiah baru yang membuktikan bahwa metode automated scanning dan kalkulasi numerik standar industri (CVSS v3) dapat diimplementasikan secara presisi untuk mengukur tingkat risiko siber pada domain-domain berbasis komunitas keagamaan.

1.4.2 Manfaat Bagi Kemaslahatan Umat/Institusi (Praktis)

- Bagi Pengelola Teknologi Pesantren (Asatidzah / IT Team). Hasil penelitian ini dapat dijadikan sebagai draf teknis dan panduan evaluasi mandiri untuk melakukan tindakan penambalan (patching) celah keamanan. Hal ini merupakan wujud nyata dari upaya menjaga amanah perlindungan data serta haibah/marwah institusi pesantren dari potensi kejahatan siber (mudharat era digital).
- Bagi Pengambil Kebijakan Pendidikan Islam (Kemenag / MUI): Memberikan data statistik riil mengenai urgensi standarisasi keamanan digital, sehingga dapat mendorong lahirnya kebijakan yang lebih sistematis dalam memproteksi aset-aset digital milik umat di Indonesia.

1.5 Batasan Masalah

Agar penelitian ini berjalan secara fokus, efisien, serta tetap menjaga koridor etika/adab siber (tidak melakukan tindakan hacking merusak yang dilarang), maka ditetapkan 5 (lima) butir batasan masalah komputasi sebagai berikut:

1. Dataset / Objek Penelitian: Objek penelitian dibatasi hanya pada website resmi milik Pondok Pesantren di Indonesia yang statusnya aktif, di bawah Yayasan Al Irsyad, dan dapat diakses secara publik oleh masyarakat luar.
2. Metode / Algoritma: Evaluasi keamanan hanya dilakukan pada tahap Vulnerability Assessment (pemindaian celah) menggunakan metode pemindaian otomatis (automated scanning), lalu dikonversi menggunakan metrik kuantitatif CVSS v3. Penelitian ini tidak melakukan tahapan eksploitasi (penetration testing agresif) yang dapat mengganggu ketersediaan (availability) sistem atau merusak database website mitra.
3. Perangkat Keras (Hardware): Proses pemindaian dan pengolahan data numerik dilakukan menggunakan 1 (satu) unit laptop pribadi peneliti dengan spesifikasi teknis: Prosesor Intel Core i7-13620H, RAM 8 GB, NVIDIA GeForce RTX 4060.
4. Perangkat Lunak (Software): Perangkat lunak utama yang digunakan dalam eksperimen ini adalah Sistem Operasi Windows 11, aplikasi pemindai OWASP ZAP Core Engine v2.14.0 (atau versi terbaru yang stabil), browser Google Chrome, serta kalkulator resmi CVSS v3 berbasis web.
5. Parameter Penelitian: Parameter kuantitatif yang diukur dan dianalisis dalam riset ini dibatasi hanya pada aspek teknis sistem, yaitu: jumlah peringatan keamanan (vulnerability alerts), kategori kerentanan berdasarkan OWASP Top 10, serta nilai numerik skor keparahan risiko (skala 0.0 sampai 10.0). Penelitian ini tidak membahas faktor social manusia seperti tingkat kesadaran (cyber awareness) santri, manajemen SDM, ataupun anggaran finansial pesantren.

BAB 2 TINJAUAN PUSTAKA

2.1 Landasan Teori

2.1.1 Keamanan Aplikasi Web dan OWASP Top 10

Keamanan aplikasi web merupakan disiplin dalam ilmu komputer yang berfokus pada perlindungan sistem berbasis web dari ancaman yang dapat merusak kerahasiaan (confidentiality), integritas (integrity), dan ketersediaan (availability) data. Kerentanan web muncul akibat kesalahan konfigurasi, kelemahan kode, atau ketidaksempurnaan desain arsitektur. Open Web Application Security Project (OWASP) secara berkala merilis daftar sepuluh risiko keamanan aplikasi web paling kritis yang dikenal sebagai OWASP Top 10. Daftar ini mencakup, antara lain, Broken Access Control, Cryptographic Failures, Injection, Insecure Design, Security Misconfiguration, Vulnerable and Outdated Components, Identification and Authentication Failures, Software and Data Integrity Failures, Security Logging and Monitoring Failures, serta Server-Side Request Forgery [18]. Pemahaman terhadap kategori OWASP Top 10 menjadi dasar klasifikasi temuan kerentanan dalam penelitian ini.

2.1.2 Mekanisme Automated Vulnerability Scanning dengan OWASP ZAP

OWASP Zed Attack Proxy (ZAP) adalah perangkat lunak open-source yang dirancang untuk melakukan pengujian keamanan aplikasi web secara otomatis maupun interaktif. Arsitektur pemindaian otomatis OWASP ZAP terdiri atas dua komponen utama. Pertama, Spidering (Crawling), yaitu proses penjelajahan otomatis terhadap struktur URL dan tautan di dalam situs target untuk membangun peta situs (site tree). Spider tradisional menganalisis respons HTML, sedangkan AJAX Spider merender JavaScript untuk menangkap tautan dinamis. Kedua, Active Scan Engine, yaitu mesin yang mengirimkan payload uji (attack payloads) ke setiap endpoint yang ditemukan guna mendeteksi kelemahan aktif seperti SQL Injection, Cross-Site Scripting (XSS), Path Traversal, dan lainnya. Hasil pemindaian dikelompokkan dalam bentuk alerts dengan tingkat risiko High, Medium, Low, dan Informational [1], [2], [7].

2.1.3 Framework dan Metrik Kalkulasi CVSS v3

Common Vulnerability Scoring System version 3 (CVSS v3) adalah kerangka kerja terbuka yang dikembangkan oleh FIRST.org untuk mengukur tingkat keparahan kerentanan perangkat lunak secara numerik (skala 0.0–10.0). Kelompok metrik dasar (Base Metrics Group) terdiri atas delapan parameter [19]:

- Attack Vector (AV): mengukur jalur serangan (Network, Adjacent, Local, Physical).
- Attack Complexity (AC): tingkat kesulitan eksekusi serangan (Low, High).
- Privileges Required (PR): hak akses yang dibutuhkan penyerang (None, Low, High).
- User Interaction (UI): apakah diperlukan interaksi pengguna (None, Required).
- Scope (S): apakah dampak meluas ke komponen lain (Unchanged, Changed).
- Confidentiality (C), Integrity (I), Availability (A): dampak terhadap kerahasiaan, integritas, dan ketersediaan (None, Low, High).

Nilai-nilai parameter tersebut dikombinasikan melalui formula Impact Sub-Score (ISS), Impact, Exploitability, dan Base Score untuk menghasilkan skor keparahan numerik yang objektif dan dapat dibandingkan antar sistem.

2.2 Matriks State-of-the-Art (SOTA)

Tabel berikut merangkum sepuluh penelitian terdahulu yang relevan dengan metode automated scanning dan evaluasi kerentanan web. Kolom Research Gap menunjukkan celah yang menjadi dasar posisi penelitian ini.

No	Penulis & Tahun	Metode / Objek	Hasil Utama	Research Gap
1	Ribeiro et al. (2025)	Nmap & scanners / Web PT publik	Postur keamanan digital kampus dengan skor risiko	Tidak fokus web lembaga keagamaan
2	Neupane (2025)	OWASP ZAP, SQLMap / PHP-MySQL	Metodologi deteksi & mitigasi SQLi	Hanya fokus satu jenis celah (SQLi)
3	Potti et al. (2024)	Benchmark ZAP V2.12 vs V2.13 / Baseline	ZAP baru: akurasi ↑, FP ↓	Pengujian lab, bukan website riil

4	Swetha et al. (2024)	Nessus, Acunetix, Nikto / General	Nessus unggul akurasi CVSS	Fokus korporasi, bukan pendidikan Islam
5	Eshetu et al. (2024)	Nmap, Nessus, Vega / Web PT Ethiopia	Celah kritis server belum di-patch	Infrastruktur Afrika; belum Indonesia
6	Jarupunphol et al. (2023)	ZAP & Burp Suite / Website universitas	ZAP optimal medium-confidence	Belum uji skala menengah/pesantren
7	Lavens et al. (2022)	24 Web Scanners / 11 tipe kerentanan	ZAP recall rate tertinggi (injeksi)	Generalisasi alat; bukan kasus khusus
8	Shahid et al. (2022)	OWASP ZAP / Web App params	136 TP; 100% recall rate	Objek synthetic web, bukan aktif
9	Nurbojatmiko et al. (2022)	OWASP ZAP / Sharia crowdfunding	31 warnings (4H,5M,14L,9I)	Fokus finansial, bukan akademik pesantren
10	Mateus et al. (2021)	Automated scanners / Univ. Angola	Pengelompokan jenis celah paling sering	Tidak memakai konversi CVSS v3

2.3 Research Gap Narratives

Berdasarkan matriks SOTA di atas, research gap yang menjadi posisi penelitian ini dapat dirumuskan sebagai berikut. Pertama, sebagian besar studi sebelumnya berfokus pada website universitas berskala besar, portal pemerintahan, atau aplikasi finansial (termasuk crowdfunding syariah), namun belum menyentuh secara spesifik website resmi Pondok Pesantren di Indonesia yang memiliki karakteristik tata kelola infrastruktur mandiri dan sering kali minim sumber daya teknis. Kedua, kajian di Indonesia cenderung menitikberatkan dimensi sosial-perilaku (cybersecurity awareness, literasi digital santri) dan belum menghadirkan evaluasi komputasi murni berbasis data numerik dari hasil automated scanning. Ketiga, meskipun beberapa penelitian menggunakan OWASP ZAP, konversi temuan kerentanan ke skor keparahan standar industri CVSS v3 masih jarang diterapkan secara sistematis pada objek domain keagamaan. Penelitian ini menjembatani ketiga gap tersebut dengan melakukan vulnerability assessment otomatis pada website Pondok Pesantren di bawah Yayasan Al Irsyad dan mengukur tingkat keparahan secara kuantitatif menggunakan metrik CVSS v3, tanpa melakukan eksploitasi agresif.

2.4 Kerangka Pemikiran

Masalah (Problem): Website Pondok Pesantren di Indonesia berpotensi memiliki celah keamanan teknis akibat lemahnya patching management dan konfigurasi, namun belum tersedia data kuantitatif objektif mengenai distribusi dan tingkat keparahan kerentanan tersebut.

Pendekatan (Approach): Vulnerability Assessment menggunakan automated scanning (OWASP ZAP) yang dilanjutkan dengan konversi temuan ke skor numerik CVSS v3.

Implementasi / Eksperimen: Identifikasi target website aktif Yayasan Al Irsyad → Spidering dan Active Scan → Ekstraksi alerts → Pemetaan ke parameter CVSS v3 → Perhitungan skor dan distribusi risiko.

Hasil (Output): Jumlah dan distribusi persentase celah per kategori risiko, rata-rata skor CVSS v3, serta persentase website dengan minimal satu kerentanan High Risk ($CVSS \geq 7.0$) sebagai dasar prioritas mitigasi.

BAB 3 METODOLOGI PENELITIAN

3.1 Jenis Penelitian dan Justifikasi

Penelitian ini merupakan penelitian kuantitatif empiris (experimental/empirical quantitative research) di bidang keamanan komputer. Pendekatan kuantitatif dipilih karena tujuan utama penelitian adalah menghasilkan data numerik yang dapat diukur, dihitung, dan dianalisis secara statistik, yaitu jumlah alerts, distribusi persentase, rata-rata skor CVSS v3, dan proporsi website berisiko tinggi. Sifat empiris ditunjukkan melalui pelaksanaan pemindaian otomatis langsung terhadap objek website riil (bukan simulasi murni di laboratorium), dengan parameter dan lingkungan pengujian yang dikontrol sesuai batasan masalah. Penelitian ini tidak bersifat kualitatif atau survey persepsi, melainkan berfokus pada pengukuran teknis performa sistem.

3.2 Flowchart dan Tahapan Penelitian

[1] Persiapan Domain & Identifikasi Target



[2] Automated Scanning (OWASP ZAP: Spider + Active Scan)



[3] Ekstraksi Vulnerability Flags / Alerts



[4] Transformasi Skor Keparahan ke Metrik CVSS v3



[5] Analisis Kuantitatif & Distribusi Risiko

1. Persiapan Domain & Identifikasi Target: Mengumpulkan daftar URL website resmi Pondok Pesantren di bawah Yayasan Al Irsyad yang berstatus aktif dan dapat diakses publik. Setiap target diverifikasi ketersediaan (HTTP response) sebelum dimasukkan ke daftar pemindaian.

2. Automated Scanning (OWASP ZAP): Menjalankan Spider (traditional dan/atau AJAX) untuk membangun site tree, dilanjutkan Active Scan untuk menguji endpoint

terhadap berbagai payload kerentanan. Scan dilakukan dalam mode non-destruktif (vulnerability assessment saja).

3. Ekstraksi Vulnerability Flags/Alerts: Mengekspor laporan hasil pemindaian (jumlah alerts per kategori High, Medium, Low, Informational) beserta deskripsi jenis kerentanan yang terdeteksi.

4. Transformasi Skor Keparahan ke Metrik CVSS v3: Setiap temuan kerentanan yang relevan dipetakan ke parameter Base Metrics CVSS v3 (AV, AC, PR, UI, S, C, I, A) menggunakan kalkulator resmi, kemudian dihitung Base Score-nya.

5. Analisis Kuantitatif & Distribusi Risiko: Menghitung total alerts, persentase distribusi per kategori, rata-rata skor CVSS v3, dan proporsi website dengan minimal satu kerentanan High Risk ($CVSS \geq 7.0$).

3.3 Deskripsi Dataset

Dataset penelitian berupa sampel website resmi Pondok Pesantren di Indonesia yang berada di bawah naungan Yayasan Al Irsyad, berstatus aktif, dan dapat diakses secara publik. Kriteria inklusi: (1) domain/subdomain resmi milik pondok pesantren, (2) dapat direspons oleh server (status HTTP 2xx/3xx), dan (3) tidak berada di balik autentikasi yang menghalangi pemindaian publik. Jumlah pastinya ditentukan pada tahap persiapan setelah verifikasi ketersediaan. Penelitian ini tidak menggunakan dataset sintetis atau aplikasi tiruan; seluruh target merupakan website operasional riil.

3.4 Arsitektur Metode dan Algoritma Pemindaian

Alur kerja teknis OWASP ZAP dalam penelitian ini mengikuti urutan: (1) penambahan URL target ke Sites tree, (2) eksekusi Spider untuk penemuan sumber daya (URL, form, parameter), (3) eksekusi Active Scan yang mengirimkan serangkaian attack payloads sesuai policy yang dipilih, dan (4) pengumpulan alerts. Spider bekerja dengan mengikuti tautan HTML (traditional spider) dan/atau merender halaman melalui browser (AJAX spider) untuk menangkap konten dinamis. Active Scan Engine kemudian menguji setiap node yang ditemukan terhadap rule-set kerentanan bawaan ZAP (termasuk deteksi terkait OWASP Top 10). Seluruh proses dijalankan dalam mode assessment (tanpa upaya eksploitasi lanjutan yang mengubah data atau mengganggu ketersediaan layanan).

3.5 Skenario Pengujian dan Baseline

Konfigurasi pemindaian menggunakan policy default OWASP ZAP yang mencakup rule untuk kategori risiko utama, dengan threshold dan strength disesuaikan agar tetap non-destruktif (menghindari payload yang berpotensi menyebabkan denial-of-service). Setiap target dipindai secara independen. Baseline yang digunakan adalah kategori risiko bawaan ZAP (High, Medium, Low, Informational) serta skor CVSS v3 resmi. Tidak dilakukan perbandingan antar alat scanner lain; fokus penelitian adalah pengukuran kuantitatif pada objek pesantren menggunakan satu alat standar (OWASP ZAP) ditambah konversi CVSS v3.

3.6 Metrik Evaluasi dan Formula Matematis

3.6.1 Persentase Distribusi Celah Keamanan

Untuk setiap kategori risiko $k \in \{\text{High, Medium, Low, Informational}\}$:

$$P_k = (N_k / N_{\text{total}}) \times 100\%$$

di mana N_k adalah jumlah alerts pada kategori k , dan N_{total} adalah jumlah total alerts yang terdeteksi.

3.6.2 Formula CVSS v3 Base Score

Sesuai spesifikasi resmi FIRST.org CVSS v3.1 [19]:

$$ISS = 1 - [(1 - C) \times (1 - I) \times (1 - A)]$$

$$\text{Impact (Scope Unchanged)} = 6.42 \times ISS$$

$$\text{Impact (Scope Changed)} = 7.52 \times (ISS - 0.029) - 3.25 \times (ISS - 0.02)^{15}$$

$$\text{Exploitability} = 8.22 \times AV \times AC \times PR \times UI$$

$$\text{Base Score (Scope Unchanged)} = \text{Roundup}(\text{Min}[(\text{Impact} + \text{Exploitability}), 10])$$

$$\text{Base Score (Scope Changed)} = \text{Roundup}(\text{Min}[1.08 \times (\text{Impact} + \text{Exploitability}), 10])$$

Jika $\text{Impact} \leq 0$ maka Base Score = 0. Nilai numerik parameter AV, AC, PR, UI, C, I, A mengikuti tabel bobot resmi CVSS v3.1. Rata-rata skor dihitung dari seluruh Base Score yang dihasilkan per temuan kerentanan yang dipetakan.

3.7 Environment Pengujian

Spesifikasi lingkungan pengujian sesuai batasan masalah disajikan pada tabel berikut.

Komponen	Spesifikasi
Prosesor	Intel Core i7
Memori (RAM)	8 GB
GPU	NVIDIA GeForce RTX 4060
Sistem Operasi	Windows 11
Aplikasi Pemindai	OWASP ZAP Core Engine v2.14.0 (atau versi stabil terbaru)
Browser	Google Chrome
Kalkulator CVSS	Kalkulator resmi CVSS v3 berbasis web (FIRST.org)

3.8 Jadwal Penelitian

Rencana pelaksanaan penelitian disusun dalam bentuk tabel Gantt bulanan sebagai berikut.

Kegiatan	Bln1	Bln2	Bln3	Bln4	Bln5	Bln6
Persiapan domain & identifikasi target	■					
Konfigurasi OWASP ZAP & uji coba	■	■				
Automated scanning (Spider + Active Scan)		■	■			

Ekstraksi alerts & mapping CVSS v3						
Analisis kuantitatif & distribusi risiko						
Penulisan laporan & penyusunan skripsi						

DAFTAR PUSTAKA

- [1] E. Lavens, P. Philippaerts, dan W. Joosen, "A Quantitative Assessment of the Detection Performance of Web Vulnerability Scanners," dalam *Proceedings of the 17th International Conference on Availability, Reliability and Security*, Vienna, Austria: ACM, Agu. 2022, hlm. 1–10. doi: 10.1145/3538969.3544416.
- [2] J. Shahid, M. K. Hameed, I. T. Javed, K. N. Qureshi, M. Ali, dan N. Crespi, "A Comparative Study of Web Application Security Parameters: Current Trends and Future Directions," *Appl. Sci.*, vol. 12, no. 8, hlm. 4077, Apr. 2022, doi: 10.3390/app12084077.
- [3] P. Jarupunphol, S. Seatun, dan W. Buathong, "Measuring Vulnerability Assessment Tools' Performance on the University Web Application," *Pertanika J. Sci. Technol.*, vol. 31, no. 6, hlm. 2973–2993, Okt. 2023, doi: 10.47836/pjst.31.6.19.
- [4] D. Ribeiro, V. Fonte, L. F. Ramos, dan J. M. Silva, "Assessing the information security posture of online public services worldwide: Technical insights, trends, and policy implications," *Gov. Inf. Q.*, vol. 42, no. 2, hlm. 102031, Jun. 2025, doi: 10.1016/j.giq.2025.102031.
- [5] A. Y. Eshetu, E. A. Mohammed, dan A. O. Salau, "Cybersecurity vulnerabilities and solutions in Ethiopian university websites," *J. Big Data*, vol. 11, no. 1, hlm. 118, Agu. 2024, doi: 10.1186/s40537-024-00980-z.
- [6] B. P. Salsabila, H. Endah Wahanani, dan A. Junaidi, "Uncovering Hidden Security Risks in Government Web Portals Using Penetration Testing and Attack Modeling," *Bit-Tech*, vol. 8, no. 3, hlm. 4034–4043, Apr. 2026, doi: 10.32877/bt.v8i3.3776.
- [7] U.-S. Potti, H.-S. Huang, H.-T. Chen, dan H.-M. Sun, "Security Testing Framework for Web Applications: Benchmarking ZAP V2.12.0 and V2.13.0 by OWASP as an example," 2024.
- [8] Nurbojatmiko, A. Lathifah, F. Bil Amri, dan A. Rosidah, "Security Vulnerability Analysis of the Sharia Crowdfunding Website Using OWASP-ZAP," dalam *2022 10th International Conference on Cyber and IT Service Management (CITSM)*, Yogyakarta, Indonesia: IEEE, Sep. 2022, hlm. 1–5. doi: 10.1109/CITSM56380.2022.9935837.
- [9] E. Mateus dan C. Serrão, "Vulnerability Assessment of Angolan University Web Applications," dalam *Proceedings of the 17th International Conference on Web Information Systems and Technologies, SCITEPRESS*, 2021, hlm. 518–525. doi: 10.5220/0010716800003058.
- [10] S. Qadir, E. Waheed, A. Khanum, dan S. Jehan, "Comparative evaluation of approaches & tools for effective security testing of Web applications," *PeerJ Comput. Sci.*, vol. 11, hlm. e2821, Apr. 2025, doi: 10.7717/peerj-cs.2821.
- [11] F. P. E. Putra, U. Ubaidi, A. Hamzah, W. A. Pramadi, dan A. Nuraini, "Systematic Literature Review: Security Gap Detection On Websites Using Owasp Zap," *Brilliance: Research of Artificial Intelligence*, vol. 4, no. 1, hlm. 348–355, Jun. 2024, doi: 10.47709/brilliance.v4i1.4227.
- [12] E. Fahrudin, R. Subariah, dan N. Nurhidayatuloh, "Pentingnya Memahami Cyber Security di Era Transformasi Digital pada Pesantren Daar El Manshur Depok," *JIPM J. Inov. Pengabd. Masy.*, vol. 2, no. 1, hlm. 25–28, Jan. 2024, doi: 10.55903/jipm.v2i1.143.
- [13] R. Rizal dkk., "KEWASPADAAN PENYALAHGUNAAN DATA PRIBADI PADA SANTRI DI ERA DIGITAL," vol. 02, 2023.
- [14] G. E. Agusta, N. Astriawati, dan P. S. Santosa, "Edukasi Bijak Bermedsos: Membangun Literasi Digital untuk Santri Cerdas dan Beretika," *J. Pengabd. Kpd. Masy.*, vol. 02, no. 02, 2025.

-
- [15] M. Syafiih, Nadiyah, M. Khairi, Moh. Furqan, dan Beny Yusman, "Pendampingan Literasi Digital untuk Mengurangi Risiko Kejahatan Siber Membentuk Masyarakat yang Lebih Aman," JILPI J. Ilm. Pengabd. Dan Inov., vol. 2, no. 4, hlm. 1027–1036, Jun. 2024, doi: 10.57248/jilpi.v2i4.456.
- [16] S. Neupane, "Detecting and Mitigating SQL Injection Vulnerabilities in Web Applications," arXiv:2506.17245, Jun. 2025. doi: 10.48550/arXiv.2506.17245.
- [17] S. B, S. S, T. J, dan S. Nrk, "A Comparative Analysis of Vulnerability Management Tools: Evaluating Nessus, Acunetix, and Nikto for Risk-Based Security Solutions," SSRN, 2025. doi: 10.2139/ssrn.5036282.
- [18] OWASP Foundation, "OWASP Top 10:2021 – The Ten Most Critical Web Application Security Risks," 2021. [Online]. Available: <https://owasp.org/Top10/2021/>
- [19] FIRST.org, "Common Vulnerability Scoring System version 3.1: Specification Document," 2019. [Online]. Available: <https://www.first.org/cvss/v3.1/specification-document>
- [20] OWASP Foundation, "OWASP Zed Attack Proxy (ZAP) Documentation," 2024. [Online]. Available: <https://www.zaproxy.org/docs/>
- [21] E. Altulaihan, A. S. Alismail, and M. Frikha, "A Survey on Web Application Penetration Testing," Electronics, vol. 12, no. 5, Art. no. 1229, Mar. 2023, doi: 10.3390/electronics12051229.
- [22] S. Alazmi dan D. C. de Leon, "A Systematic Literature Review on the Characteristics and Effectiveness of Web Application Vulnerability Scanners," IEEE Access, vol. 10, hlm. 33200–33219, 2022, doi: 10.1109/ACCESS.2022.3161522.